

Мышление атакующего: Как Red Team использует психологию и находит путь внутрь

 redsec.by/article/myshlenie-atakuyushhego-kak-red-team-ispolzuet-psihologiyu-i-nahodit-put-vnutr

Red Teams | 6 января 2026



В современной индустрии информационной безопасности существует опасное заблуждение: многие полагают, что защищенность организации прямо пропорциональна бюджету, потраченному на программно-аппаратные комплексы. Однако, как показывает практика профессиональных Red Team подразделений, даже самая совершенная технологическая «крепость» может пасть не из-за программной уязвимости, а из-за фундаментальных особенностей человеческой психики.

Почему технология не решает проблему

Представьте классическую ситуацию в крупном корпоративном секторе: компания инвестирует \$500,000 в современный NGFW (Next-Generation Firewall), активирует расширенные модули Threat Detection, нанимает штат квалифицированных SOC-аналитиков и внедряет концепцию Zero Trust. На бумаге и в отчетах перед советом директоров это выглядит как неприступная цитадель.

Но Red Team всё равно заходит внутрь. И делает это с пугающей регулярностью. Причина здесь не в том, что Firewall плох или аналитики ленивы. Проблема в векторе атаки. В то время как защитники (Blue Team) строят стены и скрупулезно анализируют логи, Red Team атакует не биты и байты. Они атакуют людей.

Это ключевое различие в парадигмах мышления. Для классического ИТ-департамента безопасность — это набор правил, паттернов и конфигураций. Для атакующего — это поиск слабого звена в сложной системе, где человек является наиболее нестабильным и уязвимым компонентом. Red Team изучает, как работает

наше мышление, где мы принимаем импульсивные решения и в каких ситуациях мы становимся слепы к очевидным угрозам. Самые успешные взломы последнего десятилетия начинались не с Zero-day эксплойта, а с понимания когнитивной психологии.

Три когнитивных искажения: Фундамент для успешных атак

Наш мозг — это результат миллионов лет эволюции, оптимизированный для выживания в дикой природе, а не для работы с цифровыми угрозами. Мы используем «эвристики» — ментальные сокращения, позволяющие принимать быстрые решения. Именно эти сокращения Red Team превращает в инструменты взлома.

1. Смещение к авторитету (Authority Bias)

Механизм: Человеческий мозг склонен доверять людям, занимающим высокую позицию в иерархии. Эволюционно это было оправдано: подчинение вождю или опытному охотнику повышало шансы племени на выживание. В корпоративной среде этот инстинкт трансформируется в автоматическое выполнение приказов руководства без должной верификации.

Как Red Team это эксплуатирует: Атака начинается с глубокой разведки (OSINT). Изучается стиль письма CEO, его график командировок, текущие бизнес-проекты. Письмо, пришедшее якобы от генерального директора, не просто содержит требование — оно пропитано контекстом, который делает его легитимным в глазах сотрудника.

Пример сценария: "Мне срочно нужно перевести \$250,000 на счёт для закрытого контракта. Я сейчас на встрече, телефон недоступен. Деньги должны уйти до конца часа на этот счёт (поддельный реквизит). Никому не говорите — это сделка под NDA".

Статистика, отражающая масштаб проблемы:

- **89%** всех BEC-атак (Business Email Compromise) строятся на имперсонации руководства.
- **64%** руководителей высшего звена (Senior IT Leaders) попадают на фишинг, несмотря на глубокие технические знания.
- У IT-руководителей вероятность стать жертвой персонализированного ИИ-фишинга на **23% выше**, чем у рядовых сотрудников.
- При этом **76%** топ-менеджеров уверены в неуязвимости своей компании, даже если их собственные учетные данные уже скомпрометированы.

Реальный кейс из практики: Крупная производственная компания. CFO получает письмо от CEO, который официально находится в командировке в Германии. Письмо

содержит просьбу о срочном трансше в \$250,000. Совпадение контекста (СЕО действительно в Германии) и магия авторитета полностью отключили критическое мышление. Проверка по второму каналу связи не была проведена. Результат: средства ушли на оффшорный счет Red Team.

Почему это работает? Авторитет парализует логику. Включается режим «подчинения». Мозг диктует: «Если это начальник — это важно. Если это важно — это нужно сделать немедленно. Если нужно сделать немедленно — лишние вопросы неуместны».

2. Эффект срочности (Urgency Effect)

Механизм: Время в нашем восприятии эквивалентно угрозе. Когда возникает дефицит времени, мозг переходит из режима медленного, аналитического мышления (Система 2 по Канеману) в режим быстрого, инстинктивного реагирования (Система 1).

Как Red Team это эксплуатирует: Атаки часто проводятся в периоды повышенного стресса или усталости — например, в пятницу вечером перед закрытием офиса. Темы писем кричат о катастрофе: «СРОЧНО», «Ваш аккаунт будет заблокирован через 10 минут», «Немедленно подтвердите транзакцию».

Статистические данные:

- Сотрудники под жестким дедлайном кликают по фишинговым ссылкам в **3 раза чаще**.
- Эффект срочности снижает когнитивную нагрузку на обработку деталей (например, проверку домена отправителя) практически до нуля.
- В атаке на британскую энергокомпанию deepfake-голос СЕО требовал перевод £200,000 за 30 минут до конца рабочего дня.

Реальный пример (Vishing + Deepfake): Руководитель подразделения получает звонок. Голос с характерным немецким акцентом, идеально имитирующий СЕО материнской компании, требует немедленного перевода £200,000 поставщику. «Сделка сорвется через полчаса, если денег не будет. Я на конференции, связи нет, только этот канал. Действуй!». Голос был синтезирован с помощью ИИ на основе публичных выступлений СЕО на YouTube. Жертва не стала сомневаться и выполнила перевод.

3. Предвзятость подтверждения (Confirmation Bias) у защитников

Механизм: Это самое опасное искажение, поражающее профессионалов. Мы склонны искать информацию, которая подтверждает нашу существующую точку зрения, и игнорировать ту, что ей противоречит.

Как это работает в ИБ: После покупки дорогостоящего решения (например, Palo Alto NGFW или SIEM-системы) у команды безопасности возникает ложное чувство «выполненного долга». Они подсознательно верят, что «теперь мы в безопасности».

- Firewall стоит? Значит, периметр закрыт.
- SIEM работает? Значит, мы видим всё.
- EDR развернут? Значит, малварь не пройдет.

В реальности же Red Team использует техники **Living Off The Land (LOTL)**, которые не создают аномальных файлов, а используют легитимные инструменты системы (PowerShell, WMI, BITS). Защитник, ослепленный предвзятостью подтверждения, видит в логах работу системного администратора, а не атакующего.

Проблема Alert Fatigue (усталость от уведомлений):

- SOC-аналитик получает до **10,000 алертов** в сутки.
- Через 12 часов смены точность распознавания угроз падает на **40%**.
- **Каждый третий алерт** игнорируется как False Positive (ложноположительный).
- Возникает «спираль смерти»: больше алертов → больше шума → выгорание → пропуск реальной атаки.

Технический разбор: Когда "безопасная" конфигурация становится дверью

Рассмотрим пример с тем самым NGFW от Palo Alto. Компания уверена в защите, но Red Team проводит разведку. Сканирование портов возвращает статус filtered на всех портах. Казалось бы, всё идеально — файрвол «дропает» пакеты.

Однако, при глубоком анализе выясняется, что устройство использует **SYN Cookies** для защиты от DDoS-атак. Это приводит к тому, что на этапе TCP Handshake файрвол отвечает на SYN-пакеты, даже если порт закрыт, чтобы проверить легитимность соединения. Для атакующего это сигнал о том, как работает стек протоколов защиты.

В ходе аудита Red Team обнаруживает правило, разрешающее трафик из «доверенного сегмента». Из-за ошибки в маске подсети (misconfiguration), точка входа атакующего попала в этот диапазон. Файрвол формально работал, но логика правил содержала фатальную брешь. Никто из Blue Team не проверял это правило месяцами, потому что «система же работает».

Жизненный цикл Red Team атаки: Точки психологического воздействия

Профессиональная атака — это не хаотичный набор действий, а выверенный процесс, где на каждом этапе эксплуатируется конкретное человеческое несовершенство.

Этап 1: Разведка (Reconnaissance)

- **Действие:** Сбор OSINT, анализ соцсетей сотрудников, поиск публичных документов.
- **Искажение:** Подтверждение у защитников. Они полагаются на то, что «публичная информация неопасна».
- **Результат:** Red Team знает структуру компании лучше, чем HR.

Этап 2: Начальный доступ (Initial Access)

- **Действие:** Таргетированный фишинг или вишинг (Vishing).
- **Искажение:** Смещение к авторитету + Эффект срочности.
- **Инструментарий:** Использование сервисов вроде Evilginx2 для обхода MFA (многофакторной аутентификации) через Проху-фишинг.

Этап 3: Боковое движение (Lateral Movement)

- **Действие:** Перемещение внутри сети, поиск контроллера домена.
- **Искажение:** Loss Aversion (нежелание признавать потерю контроля). Защитники до последнего цепляются за стандартные паттерны детекции, игнорируя нестандартное поведение легитимных учетных записей.

Этап 4: Закрепление (Persistence)

- **Действие:** Установка бэкдоров через Scheduled Tasks или WMI Event Subscriptions.
- **Искажение:** Невнимательная слепота. Активность атакующего выглядит как рутинная работа системного администратора.
- **Пример кода (PowerShell для закрепления):**

```
$Action = New-ScheduledTaskAction -Execute 'powershell.exe' -Argument '-NoProfile -W  
$Trigger = New-ScheduledTaskTrigger -AtLogOn  
Register-ScheduledTask -Action $Action -Trigger $Trigger -TaskName "SystemUpdateChec
```

Этот код не вызывает подозрений у большинства EDR, так как создание задач — стандартный процесс Windows.

Этап 5: Эксфильтрация (Exfiltration)

- **Действие:** Вывод данных.
- **Искажение:** Alert Fatigue. Трафик маскируется под DNS-запросы или HTTPS-сессии к облачным хранилищам (Google Drive, Dropbox), которые разрешены политиками компании.

Философия Red Team: Почему они всегда на шаг впереди?

Red Team не всегда превосходит Blue Team в техническом плане. Разница в парадигме мышления. Blue Team мыслит как **автомат**: «Есть сигнатура — есть реакция».

Red Team мыслит как **адаптивный организм**: «Где защитник ожидает меня увидеть? Значит, я пойду там, где он слеп».

Вопросы, которые задает Red Team:

- Какую технику мониторинга защитник считает абсолютно надежной? (Там и будем прятаться).
- Какие алерты в этой компании обычно помечают как False Positive? (Именно их мы будем генерировать).
- Чьему письму в этой компании никто не посмеет возразить?

В то время как Blue Team защищает инфраструктуру, Red Team атакует **процессы принятия решений**.

Как это использовать для защиты: Практические рекомендации

Понимание когнитивных искажений — это первый шаг к построению реальной безопасности.

Для Blue Team и руководства:

- **Разрушение иерархических паттернов:** Внедрите обязательную верификацию любых финансовых или административных запросов через второй, независимый канал связи (Out-of-band verification). Если CEO пишет в Telegram — позвоните ему по корпоративному телефону.
- **Борьба с Alert Fatigue:** Качество важнее количества. Лучше иметь 10 настроенных правил, на которые аналитик реагирует мгновенно, чем 1000 «шумных» правил, которые приучают команду игнорировать оповещения.
- **Регулярный гигиенический аудит правил:** Не доверяйте конфигурации, которая «просто работает». Правила Firewall и политики EDR должны проходить ревизию раз в квартал.

- **Purple Teaming:** Переходите от конфронтации Red vs Blue к сотрудничеству. Проводите совместные сессии, где Red Team показывает, как именно они обошли детекцию, а Blue Team тут же настраивает новые правила.

Для сотрудников:

- **Правило 30 секунд:** При получении «срочного» запроса сделайте паузу. Срочность — это главный признак социальной инженерии.
- **Критическое отношение к контексту:** Если письмо содержит факты, которые «мог знать только начальник», помните — Red Team тоже провела разведку.

Психология как высшая форма взлома

Red Team находит путь внутрь не потому, что технологии слабы. А потому, что человеческий мозг имеет предсказуемые шаблоны. Мы верим авторитетам, мы теряем голову под давлением времени, мы становимся невнимательными после рутинной работы.

Профессиональный атакующий — это прежде всего психолог, который умеет пользоваться техническим инструментарием. До тех пор, пока мы будем строить защиту исключительно вокруг серверов, игнорируя особенности человеческого мышления, Red Team будет находить открытые двери в самых защищенных крепостях мира.

Настоящая кибербезопасность начинается не с покупки нового софта, а с осознания собственной уязвимости перед лицом психологических манипуляций.